

Módulo 2

Redes, Seguridad, Bases de Datos y Gestión

Centro de
e-Learning



UTN.BA
UNIVERSIDAD TECNOLÓGICA NACIONAL
FACULTAD DE INGENIERÍA DE BAHÍA BLANCA



Unidad 7: Seguridad, Identidad y Monitoreo

Organización del segundo módulo

- **Clase 5:** Amazon VPC + subredes publicas y privadas + NAT Gateway + Internet Gateway + Route Tables + ACLs + Security Groups + Amazon Route 53
- **Clase 6:** Almacenamiento avanzado en AWS + Versionado, ciclo de vida y politicas de bucket + AWS backup + Amazon RDS + DynamoDB
- **Clase 7:** Usuarios, grupos, politicas y MFA + principio de menor privilegio + CloudWatch y CloudTrail + AWS Config + AWS Shield y KMS
- **Clase 8:** pricing en AWS + Cost Explorer + Billing Dashboard + presupuestos + TCO + Certificaciones + cierre del curso

IAM (Identity and Access Management)

IAM es un servicio que permite controlar el acceso a los recursos de AWS. A través de IAM, es posible definir quién puede acceder a la cuenta y qué acciones puede realizar sobre los distintos servicios.

Una de sus principales ventajas es que permite aplicar el principio de seguridad de “no acceso por defecto”, es decir, ningún usuario tiene permisos hasta que se le asignan explícitamente. Esto reduce significativamente el riesgo de accesos no autorizados.

IAM es un **servicio global** (no depende de una región) y se integra con prácticamente todos los servicios de AWS.

Para utilizar IAM correctamente, es fundamental entender sus componentes principales:

usuarios, grupos, roles y políticas.

Usuarios (Users)

Un **usuario** en IAM representa una **persona** o **aplicación** que necesita acceso a AWS. Cada usuario tiene credenciales propias, que pueden ser:

- Usuario y contraseña (para acceder a la consola)
- Access Key y Secret Key (para acceso programático vía API o CLI)

En entornos reales, es **recomendable crear un usuario individual por persona**, en lugar de compartir credenciales.

Grupos (Groups)

Los **grupos** permiten organizar usuarios y asignar permisos de **forma colectiva**. En lugar de asignar permisos usuario por usuario, se pueden definir a nivel de grupo.

Por ejemplo:

- Grupo “Developers” con acceso a ciertos servicios
- Grupo “Admins” con acceso completo

Esto **simplifica la administración y evita errores.**

Políticas (Policies)

Las **políticas** son el corazón de IAM. Son documentos en formato JSON que definen qué acciones están permitidas o denegadas sobre determinados recursos.

Una política responde básicamente a tres preguntas:

- ¿Qué acción se permite? (ej: leer, escribir, eliminar)
- ¿Sobre qué recurso? (ej: un bucket, una base de datos)
- ¿En qué condiciones?

Las políticas pueden ser:

- Administradas por AWS (predefinidas)
- Personalizadas (creadas por el usuario)

Ejemplo simple: permitir leer archivos de un bucket S3 pero no eliminarlos.

Roles

Un **rol** es una identidad que no está asociada a un usuario específico, sino que puede ser asumida temporalmente por usuarios o servicios.

Los roles son muy utilizados para:

- Dar permisos a servicios (ej: una instancia EC2 que accede a S3)
- Acceso entre cuentas
- Accesos temporales más seguros

A diferencia de los usuarios, los roles no tienen credenciales permanentes.

Autenticación multifactor (MFA)

La **autenticación multifactor (MFA)** es una capa adicional de seguridad que requiere más de un método de verificación para acceder a una cuenta.

Además de la contraseña, el usuario debe ingresar un código generado por una aplicación o dispositivo.

Esto reduce significativamente el riesgo de acceso no autorizado, incluso si las credenciales son comprometidas.

AWS recomienda especialmente habilitar MFA para:

- Usuarios administradores
- La cuenta root

Buenas practicas y errores comunes

En primer lugar, se recomienda **no utilizar la cuenta root para tareas diarias**, ya que esta posee acceso total a todos los recursos. En su lugar, es preferible crear usuarios individuales para cada persona, evitando compartir credenciales.

Además, resulta clave **asignar permisos a través de grupos** en lugar de hacerlo directamente sobre cada usuario, lo que simplifica la administración y reduce errores. También es importante aplicar el **principio de menor privilegio**, otorgando únicamente los permisos necesarios para cada tarea.

Evitar asignar permisos excesivos, como acceso completo cuando no es necesario. También es habitual no utilizar grupos o roles, lo que genera configuraciones difíciles de mantener. La falta de MFA y el uso compartido de credenciales entre usuarios son prácticas especialmente riesgosas

Principio del menor privilegio

El **principio de menor privilegio** implica que cada usuario, grupo o rol debe tener acceso solo a los recursos y acciones que necesita para cumplir su función específica.

Por ejemplo, si un usuario solo necesita leer archivos en un bucket, no debería tener permisos para eliminarlos o modificarlos. De la misma forma, una aplicación que solo consulta una base de datos no debería poder borrarla.

Este enfoque reduce la superficie de ataque y limita el impacto en caso de que una credencial sea comprometida.

Principio del menor privilegio – como aplicarlo

Aplicar el principio de menor privilegio no significa simplemente “dar pocos permisos”, sino dar los permisos correctos.

Esto se logra mediante:

- Definir políticas específicas en lugar de usar permisos amplios
- Asignar permisos según el rol del usuario (por ejemplo: desarrollador, administrador, analista)
- Utilizar roles para servicios en lugar de credenciales manuales
- Limitar acciones (read, write, delete) según necesidad
- Restringir acceso a recursos específicos (por ejemplo, un bucket puntual en lugar de todos)

En muchos casos, se comienza con permisos mínimos y se van ampliando solo si es necesario.

AWS Organizations

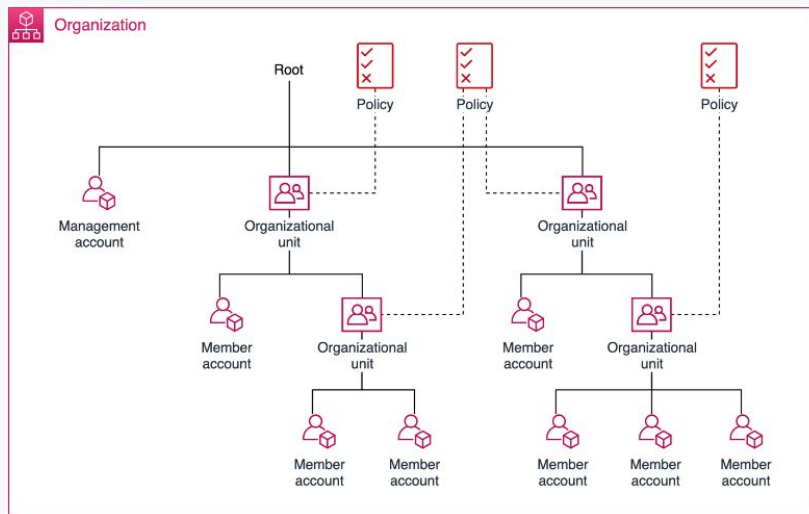
AWS Organizations es un servicio que permite agrupar varias cuentas de AWS bajo una misma estructura organizativa. Esto facilita la administración, ya que permite aplicar políticas, controlar accesos y consolidar facturación desde una cuenta principal.

Dentro de Organizations, existe una cuenta central llamada cuenta de administración (**management account**), que es la encargada de crear y gestionar el resto de las cuentas.

Las demás cuentas, llamadas **cuentas miembro**, se utilizan para distintos fines, como entornos de desarrollo (dev), producción (prod) o áreas específicas del negocio.

AWS Organizations – Unidades Organizativas

Dentro de AWS Organizations, las cuentas pueden agruparse en Unidades Organizativas (Organizational Units – OUs). Las OUs permiten estructurar las cuentas de forma jerárquica. Por ejemplo: OU “Produccion”, OU “Desarrollo”, OU “Finanzas”.



Monitoreo y trazabilidad en la nube

En cualquier sistema en la nube, no alcanza solo con desplegar recursos: es fundamental poder **observar** qué está ocurriendo, **detectar problemas y auditar acciones**. Esto permite mantener la estabilidad del sistema, optimizar el rendimiento y **garantizar la seguridad**.

En AWS, estas necesidades se cubren principalmente con dos servicios clave: **Amazon CloudWatch** y **AWS CloudTrail**.

Aunque suelen confundirse, cumplen funciones diferentes pero complementarias: uno se enfoca en el monitoreo del rendimiento y el estado de los recursos, mientras que el otro registra las acciones realizadas dentro de la cuenta.

Amazon CloudWatch

Amazon CloudWatch es el servicio de **monitoreo** de AWS. Permite recopilar métricas, logs y eventos de los recursos en tiempo real, brindando visibilidad sobre el funcionamiento de las aplicaciones y la infraestructura.

Con CloudWatch es posible responder preguntas como:

- ¿Cuánta CPU está usando una instancia EC2?
- ¿Cuántas solicitudes recibe una aplicación?
- ¿Hay errores en los logs?

Este servicio permite detectar problemas operativos y actuar rápidamente.

Amazon CloudWatch – Funcionalidades

CloudWatch ofrece varias herramientas clave:

- Métricas: datos numéricos como uso de CPU, memoria, tráfico de red, etc.
- Logs: registros de eventos generados por aplicaciones o servicios.
- Alarmas: notificaciones automáticas cuando se supera un umbral (ej: CPU > 80%).
- Dashboards: paneles visuales para monitorear múltiples recursos.

Gracias a estas funcionalidades, es posible implementar monitoreo continuo y automatizar respuestas ante incidentes.

AWS CloudTrail

AWS CloudTrail es el servicio de AWS encargado de registrar y almacenar la actividad que ocurre dentro de una cuenta. Su **función principal es proporcionar trazabilidad completa** sobre las acciones realizadas por usuarios, aplicaciones y servicios.

Cada vez que se ejecuta una acción en AWS —como crear una instancia, modificar una configuración o eliminar un recurso— CloudTrail genera un registro detallado del evento. Este registro incluye información clave como quién realizó la acción, en qué momento, desde qué dirección IP y sobre qué recurso.

CloudTrail funciona de manera continua y cubre tanto acciones realizadas desde la consola web como desde la línea de comandos (CLI) o APIs. Además, permite almacenar estos registros en servicios como S3, lo que facilita su análisis posterior y su conservación a largo plazo.

AWS CloudTrail – Importancia

AWS CloudTrail es una herramienta fundamental en términos de **seguridad**, **auditoría** y **control**. Su principal valor radica en que permite reconstruir exactamente qué ocurrió dentro de una cuenta en caso de incidentes o comportamientos inesperados.

Por ejemplo, si un recurso crítico es eliminado o modificado, CloudTrail permite identificar **quién** realizó la acción, **cuándo** y **desde dónde**. Esto es clave tanto para detectar accesos no autorizados como para analizar errores humanos.

Además, **CloudTrail** es ampliamente utilizado para cumplir con requisitos de auditoría y normativas, ya que proporciona un registro confiable y detallado de todas las actividades.

AWS CloudTrail vs CloudWatch

Una de las confusiones más comunes es la diferencia entre **CloudTrail** y **Amazon CloudWatch**, ya que ambos trabajan con información del sistema, pero tienen objetivos distintos.

CloudTrail se enfoca en la auditoría de acciones. Su objetivo es responder preguntas como: **quién hizo qué, cuándo y cómo**. Es decir, registra la actividad dentro de la cuenta, especialmente relacionada con cambios y operaciones sobre recursos.

En cambio, **CloudWatch** está orientado al monitoreo operativo. Se utiliza para observar el **rendimiento del sistema**, como uso de CPU, memoria, logs de aplicaciones o métricas en tiempo real. Su objetivo es detectar problemas de funcionamiento y ayudar a mantener la estabilidad del sistema.

AWS Config

AWS Config es un servicio de AWS que permite monitorear y registrar la configuración de los recursos en la nube a lo largo del tiempo. Su objetivo principal es mantener un historial detallado de cómo están configurados los recursos y cómo esas configuraciones van cambiando.

Cada vez que un recurso de AWS (como una instancia EC2, un bucket S3 o una base de datos) sufre una modificación, AWS Config registra ese cambio. Esto incluye no solo el estado actual del recurso, sino también versiones anteriores, lo que permite ver la evolución de su configuración.

De esta forma, AWS Config actúa como una especie de “**línea de tiempo**” de los recursos, permitiendo entender cómo estaban configurados en un momento determinado y qué cambios se realizaron.

AWS Shield

AWS Shield es un servicio diseñado para proteger aplicaciones contra ataques de denegación de servicio distribuido (**DDoS**), que buscan saturar un sistema con tráfico malicioso para dejarlo fuera de servicio.

Este servicio se encarga de detectar y mitigar automáticamente este tipo de ataques, asegurando que las aplicaciones sigan disponibles para los usuarios legítimos.

AWS Shield tiene dos niveles:

- **Shield Standard:** incluido por defecto sin costo adicional, protege contra ataques comunes
- **Shield Advanced:** ofrece protección más sofisticada, monitoreo avanzado y soporte especializado

AWS KMS

AWS Key Management Service (Key Management Service) es un servicio que permite crear, gestionar y controlar claves de cifrado utilizadas para proteger datos.

El **cifrado** es una práctica esencial para garantizar la confidencialidad de la información, tanto en reposo (almacenada) como en tránsito (en movimiento). KMS facilita este proceso al ofrecer un sistema centralizado para la gestión de claves.

AWS KMS es clave para **proteger datos sensibles**, como información personal, financiera o empresarial. Permite asegurar que solo usuarios autorizados puedan acceder a la información, incluso si los datos son expuestos.

Además, facilita el cumplimiento de normativas de **seguridad**, ya que muchas regulaciones requieren el uso de cifrado y control sobre las claves.